VICTORYAI

OUD RECOVERY COMPANION · OUTCOMES ANALYTICS PLATFORM

HIPAA & 42 CFR Part 2

Compliance Memorandum

Architecture, Controls, and the 2024 Final Rule

Applied to the BayMark Joint Innovation Pilot

PREPARED FOR

BayMark Health Services

Office of General Counsel · Privacy & Compliance · Information Security

PREPARED BY

VictoryAI Privacy & Compliance

Version 1.0 · April 2026 · Confidential

STATEMENT OF LIMITATIONS

Important Notice About This Memorandum

This memorandum is prepared by VictoryAI Privacy and Compliance for the purpose of supporting BayMark Health Services' independent legal and compliance review of the proposed joint innovation pilot. It is not a legal opinion. VictoryAI is not a law firm, and nothing in this document constitutes legal advice to BayMark.

The purpose of this document is to (a) describe VictoryAI's understanding of the regulatory framework that governs the proposed pilot, (b) document the specific technical and administrative safeguards VictoryAI has implemented or will implement, (c) identify the points at which BayMark's privacy, security, and compliance teams must independently verify VictoryAI's representations, and (d) surface any open legal or compliance questions that should be resolved before contract execution.

BayMark's legal counsel, privacy officer, information security officer, and 42 CFR Part 2 compliance officer should treat this memorandum as a starting point for their own diligence — not as a substitute for it. Where this memorandum makes statements about the law, those statements reflect VictoryAI's understanding as of April 2026, including the 2024 Final Rule modifying 42 CFR Part 2 (effective April 16, 2024, with compliance required by February 16, 2026, and now being actively enforced by the HHS Office for Civil Rights). The reader should verify all statutory and regulatory citations against current text.

TWO THINGS THIS MEMORANDUM IS AND IS NOT

It IS: a structured walkthrough of the regulatory landscape, the data flows, the technical safeguards, and the open items that BayMark's compliance and legal teams should evaluate before signing. It IS NOT: a legal opinion, a substitute for BayMark's own privacy impact assessment, or a guarantee that VictoryAI's controls will satisfy any specific BayMark policy. BayMark must conduct its own diligence.

CONTENTS

Table of Contents

Statement of Limitations ii
Executive Summary 1
Section 01 — The Regulatory Stack Governing This Pilot 3
Section 02 — VictoryAI's Status as a Business Associate 7
Section 03 — 42 CFR Part 2 and the 2024 Final Rule 9
Section 04 — HIPAA Security Rule Technical Safeguards 14
Section 05 — Data Flow Architecture and Part 2 Controls 17
Section 06 — Family Member Disclosure Architecture 20
Section 07 — Voice Data Privacy Architecture 22
Section 08 — Breach Notification 24
Section 09 — Patient Consent and Patient Notice 26
Section 10 — Subprocessors and the BAA Chain 28
Section 11 — California-Specific Considerations 30
Section 12 — Audit, Documentation, and Workforce Training 32
Section 13 — Open Items for BayMark Legal Review 34
Section 14 — VictoryAI's Compliance Commitments 36
Appendix A — Authorities and References 38
Appendix B — Glossary of Terms 40

EXECUTIVE SUMMARY

The Compliance Posture in One Page

Substance use disorder treatment data is among the most legally protected categories of health information in the United States. The combination of the HIPAA Privacy and Security Rules, the HITECH Act, and 42 CFR Part 2 creates a layered regulatory framework that imposes obligations on every entity that creates, receives, maintains, or transmits SUD treatment records — and the consequences of getting it wrong are now civil penalties under the HIPAA Enforcement Rule rather than the criminal-only regime that governed Part 2 before the 2024 Final Rule. The HHS Office for Civil Rights began civil enforcement of the modified Part 2 on February 16, 2026, and has publicly stated that Part 2 noncompliance is an enforcement priority.

This memorandum documents the specific compliance posture VictoryAI brings to the proposed BayMark joint innovation pilot. The summary in three sentences: VictoryAI operates as a HIPAA Business Associate to BayMark and as a Part 2 lawful holder of records received under a single TPO consent permitted by the 2024 Final Rule; the platform implements administrative, physical, and technical safeguards that meet the HIPAA Security Rule requirements applicable to business associates; and the architecture preserves the heightened protections that 42 CFR Part 2 continues to require for SUD records, including the new SUD counseling notes category and the limits on use in legal proceedings.

Five Things BayMark Should Verify

1. That VictoryAI is willing to execute BayMark's standard Business Associate Agreement, with reasonable additions to address the 42 CFR Part 2 lawful holder relationship.
2. That VictoryAI's HIPAA Security Risk Assessment, dated within the past 12 months, is available for BayMark's information security review prior to contract signature.
3. That VictoryAI's subprocessor list (cloud hosting, communications, AI/NLP services, customer support, monitoring) is current, that each subprocessor has executed a downstream BAA where required, and that any AI subprocessor's data handling practices are documented.
4. That VictoryAI's incident response and breach notification procedures meet the HIPAA Breach Notification Rule timing requirements (notice to BayMark without unreasonable delay and in no case later than 60 days from discovery).
5. That VictoryAI's patient consent flow, notice of privacy practices, and patient rights infrastructure (accounting of disclosures, restriction requests, complaints) align with the 2024 Final Rule's requirements.

Each of these five items is addressed in detail in the corresponding section of this memorandum. None of them is novel — they are the standard checklist items any digital health vendor should be able to satisfy. The reason this memorandum exists is to make BayMark's diligence efficient

by laying out the architecture, the controls, and the open items in one structured document, rather than requiring BayMark to extract them from a series of disconnected vendor questionnaires.

SECTION 01

The Regulatory Stack Governing This Pilot

Five distinct bodies of law govern the proposed pilot. Each imposes specific obligations on VictoryAI, on BayMark, or on both. This section provides a brief structured walkthrough of each, framed for compliance and legal review rather than for general audiences.

1.1 HIPAA Privacy Rule (45 CFR Parts 160 and 164, Subparts A and E)

The HIPAA Privacy Rule establishes national standards for the protection of individually identifiable health information held by covered entities and their business associates. BayMark is a covered entity (a healthcare provider that transmits health information in electronic form in connection with HIPAA-standard transactions). VictoryAI, as the operator of a platform that creates, receives, maintains, and transmits protected health information on BayMark's behalf, is a business associate.

The Privacy Rule's most directly relevant provisions for the pilot are: (a) the minimum necessary standard, which requires that a business associate use and disclose only the minimum PHI necessary to accomplish the intended purpose; (b) the permitted uses and disclosures framework, which allows VictoryAI to use PHI for treatment, payment, and health care operations on BayMark's behalf without separate patient authorization; and (c) the patient rights framework, which gives patients the right to access, amend, and request restrictions on their PHI.

1.2 HIPAA Security Rule (45 CFR Parts 160 and 164, Subparts A and C)

The HIPAA Security Rule requires covered entities and business associates to implement administrative, physical, and technical safeguards that ensure the confidentiality, integrity, and availability of electronic protected health information (ePHI). The Security Rule applies the same way to business associates as to covered entities, per the HITECH Act's 2009 modifications and the 2013 Omnibus Final Rule.

The Security Rule's three categories of safeguards — administrative, physical, and technical — are implemented through specific standards and implementation specifications, some labeled "required" and some "addressable." Addressable does not mean optional; it means the regulated entity must either implement the specification, implement an equivalent alternative, or document why neither is reasonable and appropriate. VictoryAI's approach to each category is documented in Section 4 of this memorandum.

BayMark should also be aware that HHS published a Notice of Proposed Rulemaking in January 2025 titled "HIPAA Security Rule To Strengthen the Cybersecurity of Electronic Protected Health Information," which proposes to convert several currently addressable specifications to required (including encryption of ePHI at rest and in transit, multi-factor authentication, and network segmentation). The proposed rule has not yet been finalized as of April 2026. VictoryAI's architecture already implements all of the proposed required specifications, so the eventual finalization of the rule will not require architectural changes to the pilot.

1.3 HIPAA Breach Notification Rule (45 CFR Parts 160 and 164, Subpart D)

The HIPAA Breach Notification Rule requires covered entities to notify affected individuals, the HHS Secretary, and in some cases prominent media outlets, following a breach of unsecured PHI. Business associates must notify the covered entity following discovery of a breach. The notification must occur without unreasonable delay and in no case later than 60 calendar days after discovery.

Critically, the 2024 Final Rule modifying 42 CFR Part 2 extended the HIPAA Breach Notification Rule to Part 2 records. Prior to the 2024 Final Rule, Part 2 had its own narrower confidentiality framework with criminal-only enforcement and no formal breach notification requirement. After the Final Rule, breaches of Part 2 records are subject to the same notification timelines and procedures as breaches of HIPAA-protected PHI. This change is one of the reasons the legal landscape for SUD digital health is materially different in 2026 than it was in 2023.

1.4 42 CFR Part 2 — Confidentiality of Substance Use Disorder Patient Records

42 CFR Part 2 is a federal regulation that has, since 1975, imposed heightened confidentiality protections on the records of patients receiving substance use disorder treatment from federally assisted programs. Part 2 applies to BayMark's BAART California clinics because they meet the definition of a Part 2 program (a federally assisted program that holds itself out as providing, and provides, substance use disorder diagnosis, treatment, or referral).

Historically, Part 2 was significantly more restrictive than HIPAA in two key ways: it required patient consent for nearly every disclosure (including disclosures for treatment, payment, and healthcare operations that HIPAA permits without authorization), and it severely limited the ability of recipients of Part 2 records to redisclose those records. The CARES Act of 2020 directed HHS to align Part 2 more closely with HIPAA, and the 2024 Final Rule implemented that directive.

WHAT CHANGED UNDER THE 2024 FINAL RULE

Single patient consent for all future TPO uses and disclosures is now permitted (previously, separate consent was required for each disclosure). HIPAA covered entities and business associates that receive Part 2 records under that consent may redisclose them in accordance with HIPAA. Disclosures to public health authorities are permitted without consent if the records are de-identified per HIPAA standards. Civil and criminal enforcement is now aligned with the HIPAA Enforcement Rule. The HIPAA Breach Notification Rule applies to breaches of Part 2 records. A new protected category — SUD counseling notes — has been created, analogous to HIPAA psychotherapy notes, requiring specific separate consent. Patients now have new rights to an accounting of disclosures and to request restrictions on certain disclosures. The express statement that segmentation of Part 2 records is not required has been added (though VictoryAI elects to segment as a defense-in-depth measure, as described in Section 5).

The 2024 Final Rule was published in the Federal Register on February 16, 2024, became effective on April 16, 2024, and required compliance by February 16, 2026. The HHS Office for Civil Rights announced its Civil Enforcement Program for Confidentiality of Substance Use Disorder Patient Records on February 13, 2026, and began accepting complaints alleging violations on February 16, 2026. Part 2 enforcement is an active OCR priority as of the date of this memorandum.

1.5 HITECH Act

The Health Information Technology for Economic and Clinical Health Act of 2009 strengthened HIPAA in several ways relevant to this pilot. Most importantly for VictoryAI, HITECH Section 13401 made the Security Rule directly applicable to business associates, including civil and criminal liability for violations. HITECH also established the breach notification framework that has now been extended to Part 2 records via the 2024 Final Rule. HITECH's tiered civil penalty structure (which can reach $2,134,831 per violation per year as of the 2024 inflation adjustment) applies to both HIPAA and Part 2 violations after February 16, 2026.

1.6 California Confidentiality of Medical Information Act (CMIA)

Because the pilot is being conducted at BayMark's California BAART clinics, the California Confidentiality of Medical Information Act (Civil Code §§ 56–56.37) also applies. CMIA generally provides protections similar to HIPAA but adds California-specific elements including private rights of action for individuals whose medical information is improperly disclosed, statutory damages, and specific provisions on the disclosure of mental health and substance use information. CMIA's preemption analysis with respect to HIPAA and Part 2 is fact-specific; in general, the more protective rule controls. BayMark's California compliance counsel should conduct the preemption analysis as part of pilot setup.

1.7 California Consumer Privacy Act / California Privacy Rights Act

CCPA and CPRA generally exempt PHI subject to HIPAA and patient information collected by covered entities or business associates in their capacity as such. However, the exemption is not absolute, and BayMark's California privacy counsel should verify that the data flows in this pilot are within the scope of the medical information exemption. VictoryAI takes the position that the patient app and provider dashboard data flows are within the HIPAA exemption to CCPA/CPRA, but this position should be independently confirmed.

1.8 Drug Medi-Cal Organized Delivery System (DMC-ODS)

BayMark's BAART California clinics participate in the California Drug Medi-Cal Organized Delivery System, which adds DHCS-specific reporting and compliance requirements on top of the federal regulatory baseline. VictoryAI's data capture and reporting architecture is designed to support BayMark's DMC-ODS reporting obligations, but the specific data elements and reporting cadences should be confirmed with BayMark's DHCS liaison during pilot setup.

SECTION 02

VictoryAI's Status as a Business Associate

Before the substantive controls discussion, this memorandum establishes the legal status of VictoryAI relative to BayMark and to the Part 2 records that will flow through the pilot. This status determines what obligations VictoryAI bears, how the patient consent must be structured, and how breaches must be reported.

2.1 Business Associate Under HIPAA

VictoryAI meets the HIPAA definition of a business associate: it is a person or entity that, on behalf of a covered entity (BayMark), creates, receives, maintains, or transmits protected health information for a function or activity regulated by HIPAA. The functions VictoryAI performs on BayMark's behalf include patient engagement support, clinical data capture, outcomes analytics, EMR-ready data export, and provider dashboard delivery. None of these are functions that BayMark could not perform itself; VictoryAI performs them as a service to BayMark.

As a business associate, VictoryAI is directly subject to the HIPAA Security Rule, the breach notification provisions of the HITECH Act, and the use and disclosure provisions of the HIPAA Privacy Rule that are made applicable to business associates by 45 CFR § 164.504(e). VictoryAI has direct civil and criminal liability for violations of these provisions and is not insulated by the BayMark BAA.

2.2 Lawful Holder Under 42 CFR Part 2

Under the 2024 Final Rule, VictoryAI also operates as a lawful holder of Part 2 records — specifically, as a HIPAA business associate that has received Part 2 records pursuant to a single TPO consent permitted by 42 CFR § 2.31. As a lawful holder, VictoryAI may use and redisclose Part 2 records in accordance with the HIPAA Privacy Rule, subject to the exceptions enumerated in Part 2 (most notably the limits on use in civil, criminal, administrative, and legislative proceedings, which are more stringent than HIPAA and which the Final Rule explicitly preserved).

VictoryAI's status as a Part 2 lawful holder creates one important obligation that is not present for non-SUD HIPAA business associates: every disclosure of Part 2 records must be accompanied by a written statement explaining that the records are subject to Part 2 and may not be used or disclosed in legal proceedings against the patient without specific consent or a court order. VictoryAI's data export and dashboard infrastructure includes this notice on every export file and every report.

2.3 Business Associate Agreement

Execution of a Business Associate Agreement between BayMark and VictoryAI is a precondition for any flow of PHI from BayMark to VictoryAI. The BAA must satisfy the requirements of 45 CFR § 164.504(e) and, given the Part 2 context, should also include provisions specific to the lawful holder relationship: (a) the obligation to include the Part 2 statement on every disclosure, (b) the prohibition on using Part 2 records in legal proceedings against the patient without specific consent or court order, (c) the SUD counseling notes consent requirement (described in Section 3.4 of this memorandum), and (d) the heightened breach notification timing if BayMark elects to require it.

VictoryAI is willing to execute BayMark's standard BAA template and to negotiate reasonable additions to address the Part 2 lawful holder context. VictoryAI's preferred approach is to start from BayMark's template rather than to propose its own, on the principle (recommended by experienced digital health attorneys) that startups that redline every clause of a health system's standard BAA lose deals. VictoryAI's negotiation focus will be on subcontractor flow-down requirements, data return or destruction at termination, and the indemnification structure — not on the substantive privacy and security obligations, which VictoryAI accepts.

SECTION 03

42 CFR Part 2 and the 2024 Final Rule

This section is the longest in the memorandum because Part 2 is the body of law most likely to surface compliance questions specific to the OUD context. This section walks through the key Part 2 provisions as modified by the 2024 Final Rule and explains how VictoryAI implements each one.

3.1 What Is a Part 2 Program

42 CFR § 2.11 defines a Part 2 program as an individual or entity (other than a general medical facility) that holds itself out as providing, and provides, alcohol or drug abuse diagnosis, treatment, or referral for treatment. The key elements are (a) federal assistance (broadly defined to include Medicare and Medicaid participation, federal tax-exempt status, and other forms of federal involvement), and (b) the holding-out element. BayMark's BAART California clinics meet both criteria because they hold themselves out as OUD treatment providers and they participate in Medicare and Medicaid.

VictoryAI itself is not a Part 2 program — it is a business associate to a Part 2 program. This distinction matters because Part 2 imposes some obligations specifically on programs (such as the SUD counseling notes structure described below) and other obligations on lawful holders of Part 2 records (such as the redisclosure notice requirement). VictoryAI bears the lawful holder obligations and supports BayMark in meeting the program-specific obligations.

3.2 The Single TPO Consent (New Under the 2024 Final Rule)

Prior to the 2024 Final Rule, Part 2 required separate patient consent for nearly every disclosure of SUD records, with each consent naming the specific recipient, the specific records to be disclosed, and the specific purpose. This requirement was widely regarded as the single largest barrier to integrating SUD treatment with general healthcare and with digital health platforms.

Under the modified 42 CFR § 2.31, a patient may now provide a single written consent for all future uses and disclosures of their Part 2 records for treatment, payment, and healthcare operations. The consent must include the specific elements enumerated in the rule (patient identification, type of disclosure permitted, recipients, purpose, expiration, revocation right, and the prohibition on conditioning treatment on consent). Once obtained, this single TPO consent permits VictoryAI to receive Part 2 records from BayMark, use them for the agreed pilot purposes, and redisclose them as permitted by HIPAA — without requiring a separate consent for each disclosure event.

VictoryAI's patient onboarding flow includes a clear, plain-language explanation of the single TPO consent and the patient's right to revoke it at any time in writing. The consent text will be developed jointly with BayMark and reviewed by BayMark's privacy officer before pilot launch. The patient may decline to provide the consent, in which case the patient cannot be enrolled in the pilot — but per § 2.31, the patient cannot be denied non-pilot BAART treatment on the basis of declining the consent.

3.3 Redisclosure Under the New Framework

Once VictoryAI receives Part 2 records under the single TPO consent, the records may be redisclosed in accordance with the HIPAA Privacy Rule — subject to the Part 2 exceptions that the 2024 Final Rule explicitly preserved. The most important preserved exception is § 2.13(a), which prohibits the use of Part 2 records, or testimony relaying their content, in any civil, criminal, administrative, or legislative proceeding against the patient, except with specific written consent or under a court order accompanied by a subpoena.

This means that a generic subpoena for VictoryAI's records is not sufficient to compel disclosure of patient SUD information for use in legal proceedings against the patient. VictoryAI's legal response procedures are designed around this rule: any subpoena, discovery request, or law enforcement request that seeks Part 2 records will be evaluated against § 2.13 and § 2.65, and VictoryAI will cooperate with BayMark in responding (including, where appropriate, contesting requests that do not satisfy the § 2.65 court order standard).

3.4 SUD Counseling Notes (New Protected Category)

The 2024 Final Rule created a new protected category called SUD counseling notes, defined as notes recorded by a SUD clinician that document the contents of a counseling session (whether group, joint, family, or individual) and that the clinician maintains separately from the rest of the patient's SUD treatment and medical record. SUD counseling notes are analogous to the psychotherapy notes category that has long existed under HIPAA and require specific patient consent for use or disclosure that cannot be satisfied by the broad TPO consent.

This new category has direct implications for VictoryAI's data architecture. VictoryAI does not capture, store, or transmit SUD counseling notes. Clinical notes that BayMark clinicians take during in-clinic counseling sessions are entered into the Kipu EMR by the clinician and remain there; VictoryAI does not pull them into its provider dashboard or its analytics layer. The data that flows from VictoryAI to BayMark's clinical team consists of patient-generated app data (MAT confirmations, check-ins, voice journal sentiment scores, CBT module completion, etc.) — not clinician-authored counseling notes.

This is a deliberate architectural choice and one that BayMark's compliance team should validate during pilot setup. The goal is to keep the new SUD counseling notes category entirely outside

the VictoryAI data perimeter, so that the heightened consent requirements for that category never need to be invoked in connection with the pilot.

3.5 Disclosures to Public Health Authorities

Under the 2024 Final Rule, Part 2 records may be disclosed to public health authorities without patient consent, provided that the records are de-identified in accordance with HIPAA standards (the Safe Harbor method or the Expert Determination method, both at 45 CFR § 164.514(b)). This change is potentially significant for BayMark's DHCS reporting obligations, because de-identified pilot outcomes data may be shared with DHCS without separate consent collection.

VictoryAI's data export infrastructure supports both Safe Harbor and Expert Determination de-identification. The default setting for any export to a public health authority is Safe Harbor de-identification, with Expert Determination available where additional analytical fidelity is required and where BayMark engages a qualified expert to perform the determination. BayMark's California compliance counsel should confirm that any specific public-health-authority disclosure planned during the pilot satisfies the relevant standard.

3.6 Patient Rights Under Part 2 (Expanded by the 2024 Final Rule)

The 2024 Final Rule added two new patient rights that align Part 2 with HIPAA. First, patients now have the right to request an accounting of disclosures of their Part 2 records made within the past three years (with the caveat that the compliance date for this specific provision was delayed pending HITECH-related rulemaking). Second, patients have the right to request restrictions on certain disclosures of their Part 2 records, mirroring the corresponding HIPAA right at 45 CFR § 164.522.

VictoryAI's platform is designed to support both rights. Every disclosure of Part 2 records is logged with the date, the recipient, the records disclosed, and the purpose. Patients (or BayMark on behalf of patients) can request an accounting of disclosures from VictoryAI through a documented support channel, and the accounting will be provided within 30 days of the request. Patient restriction requests are routed to BayMark for evaluation and, if accepted, are implemented as access controls in the VictoryAI platform within five business days.

3.7 Civil and Criminal Enforcement Under the New Framework

Prior to the 2024 Final Rule, Part 2 violations were subject to criminal penalties under 42 USC § 290dd-2 but were not subject to the civil enforcement framework that applies to HIPAA violations. The 2024 Final Rule changed this by importing the HIPAA Enforcement Rule's civil penalty structure (45 CFR Part 160, Subpart D) into Part 2. As of February 16, 2026, the HHS Office for Civil Rights has authority to impose civil penalties for Part 2 violations under the same tiered

structure that governs HIPAA violations, with annual maximums currently exceeding $2 million per violation category.

OCR announced its Civil Enforcement Program for Confidentiality of Substance Use Disorder Patient Records on February 13, 2026, and began accepting complaints on February 16, 2026. OCR has publicly stated that Part 2 noncompliance is an enforcement priority. This is the single most important reason that this memorandum exists in its current form: the enforcement landscape for SUD digital health is materially different in April 2026 than it was in 2024 or 2025, and any vendor that does not understand the new framework is a liability for its provider partners.

SECTION 04

HIPAA Security Rule Technical Safeguards

This section documents VictoryAI's implementation of the administrative, physical, and technical safeguards required by the HIPAA Security Rule. The format follows the standard structure of 45 CFR § 164.308 (administrative), § 164.310 (physical), and § 164.312 (technical), with each required and addressable specification matched to a specific VictoryAI control.

4.1 Administrative Safeguards (§ 164.308)

Security Management Process (§ 164.308(a)(1))

- Risk Analysis: VictoryAI conducts a HIPAA Security Risk Assessment annually and after any material change to the platform or to the threat environment. The most recent assessment will be made available to BayMark's information security team prior to contract execution.
- Risk Management: Identified risks are tracked in a remediation register with assigned owners, severity ratings, and target completion dates. The register is reviewed monthly by VictoryAI's security leadership.
- Sanction Policy: VictoryAI workforce members who fail to comply with security policies are subject to documented disciplinary action up to and including termination.
- Information System Activity Review: Audit logs are reviewed weekly by security operations and on-demand in response to any anomaly detected by automated monitoring.

Workforce Security and Training (§ 164.308(a)(3) and (a)(5))

- All VictoryAI workforce members complete HIPAA training at hire and annually thereafter, with documentation retained for the required six-year period.
- Workforce members with access to PHI complete additional Part 2-specific training before being granted access to Part 2 records.
- Workforce member access to PHI is reviewed quarterly and revoked immediately upon termination or role change.

Contingency Plan (§ 164.308(a)(7))

- Data Backup Plan: ePHI is backed up continuously to encrypted, geographically distributed storage with recovery point objective of 15 minutes.
- Disaster Recovery Plan: Documented recovery procedures with annual tabletop exercises. Recovery time objective of 4 hours for critical systems.
- Emergency Mode Operation Plan: Documented procedures to maintain critical security protections during emergency conditions.

4.2 Physical Safeguards (§ 164.310)

VictoryAI does not operate its own data centers. All ePHI is hosted in HIPAA-eligible AWS services (with a BAA in place between VictoryAI and AWS) and inherits AWS's physical security controls. VictoryAI workforce members do not maintain physical custody of PHI on local workstations or removable media; all access is through encrypted remote sessions to the production environment with full audit logging.

4.3 Technical Safeguards (§ 164.312)

Access Control (§ 164.312(a))

- Unique User Identification: Every workforce member and every clinician with dashboard access receives a unique credential. Shared accounts are prohibited.
- Emergency Access Procedure: Documented break-glass procedure with full audit logging.
- Automatic Logoff: Sessions terminate after 15 minutes of inactivity for the provider dashboard and after 30 minutes for the patient app.
- Encryption and Decryption: All ePHI is encrypted at rest using AES-256 and in transit using TLS 1.3 or higher. Encryption is implemented as a baseline technical control regardless of its current addressable status under § 164.312.

Audit Controls (§ 164.312(b))

- Comprehensive audit logging is implemented for every access to or modification of ePHI, including unique user ID, timestamp, source IP, action taken, and affected records.
- Audit logs are routed to a centralized SIEM with immutable storage and a retention period of at least six years per HIPAA documentation requirements.
- Failed authentication attempts, privilege escalations, and unusual access patterns trigger automated alerts to security operations.

Integrity (§ 164.312(c))

- ePHI integrity is protected through cryptographic checksums, version control, and tamper-evident audit logs.
- Database write operations are transactional with rollback capability.

Person or Entity Authentication (§ 164.312(d))

- Multi-factor authentication is required for every workforce member and every clinician dashboard user. MFA is implemented as a baseline technical control regardless of its current addressable status.
- Patient app authentication uses biometric (Face ID / fingerprint) where available, with secure passcode fallback.

Transmission Security (§ 164.312(e))

- All transmissions of ePHI use TLS 1.3 or higher with strong cipher suites.
- Integrity controls (HMAC) are applied to detect any modification of ePHI in transit.
- No ePHI is transmitted via SMS, email attachment, or other unencrypted channels.

ANTICIPATING THE 2025 SECURITY RULE NPRM

The HHS Notice of Proposed Rulemaking published in January 2025 ("HIPAA Security Rule To Strengthen the Cybersecurity of Electronic Protected Health Information") proposes to convert several currently addressable specifications to required, including encryption of all ePHI at rest and in transit, multi-factor authentication, network segmentation, vulnerability scanning, and annual business associate verification. VictoryAI's architecture already implements all of these proposed required specifications. The NPRM has not been finalized as of April 2026; when finalized, no architectural changes will be required for VictoryAI to maintain compliance.

SECTION 05

Data Flow Architecture and Part 2 Controls

This section walks through the data flows that constitute the VictoryAI platform during the BayMark pilot, identifying the specific Part 2 and HIPAA controls applied at each stage.

5.1 Patient Onboarding

A patient enrolled in the pilot is presented with the patient onboarding flow, which includes the HIPAA Notice of Privacy Practices (provided by BayMark, integrated into the VictoryAI flow), the 42 CFR Part 2 patient notice (per the 2024 Final Rule, which aligns Part 2 patient notice with HIPAA NPP requirements), and the single TPO consent form. The patient must affirmatively agree to the consent before any clinical data flows from BayMark to VictoryAI. The consent agreement is logged with timestamp, patient identifier, consent version, and patient device fingerprint.

5.2 Patient App Data Capture

As the patient uses the app, every interaction generates a structured event. Events are tagged at point of capture with a Part 2 segmentation flag (see Section 5.5). Sensitive content (voice journal audio, free-text entries that may contain identifiable information) is processed locally on the device for sentiment and feature extraction; the raw content is not transmitted. The extracted features and event metadata are encrypted on the device and transmitted to VictoryAI's HIPAA-eligible AWS environment via TLS 1.3.

5.3 Storage in the VictoryAI Production Environment

ePHI is stored in encrypted databases (AES-256 at rest) within HIPAA-eligible AWS services. VictoryAI's production environment is logically separated from its development and staging environments, with no production data ever flowing into non-production systems. Access to the production environment is restricted to a small number of VictoryAI workforce members through MFA-protected, audit-logged remote sessions.

5.4 Sync to BayMark via Kipu EMR Integration

Structured clinical data is synced to BayMark's Kipu EMR every 15 minutes via the Kipu API. The sync uses an authenticated TLS connection with mutual certificate verification. Each sync operation is logged on both the VictoryAI and Kipu sides, and reconciliation reports are generated daily to detect any sync gaps.

5.5 42 CFR Part 2 Segmentation (Defense-in-Depth)

As noted in Section 1.4, the 2024 Final Rule explicitly states that segmentation of Part 2 records is not required. VictoryAI nevertheless implements Part 2 segmentation as a defense-in-depth measure. Every data event is tagged at capture with a Part 2 flag, and the database schema separates Part 2-flagged data from non-Part 2 data at the row level. This means that even though the rule does not require it, VictoryAI's architecture preserves the ability to apply Part 2-specific access controls, audit trails, and disclosure restrictions at any future point if BayMark, DHCS, or a future regulatory change demands it.

BayMark's compliance team should regard segmentation as a value-add rather than a requirement. The architectural cost of segmentation is small; the option value of being able to apply Part 2-specific controls without re-architecting the platform is large. VictoryAI elected to incur the cost.

5.6 Provider Dashboard Access

BayMark clinicians access the provider dashboard via authenticated, MFA-protected sessions. Role-based access control limits each clinician to the patients in their assigned caseload. Every dashboard view, click, and export is audit-logged. Dashboard sessions terminate after 15 minutes of inactivity. The dashboard is read-only with respect to underlying patient app data; clinicians cannot edit patient-generated events from the dashboard, which preserves the integrity of the patient's own record.

5.7 EMR-Ready Data Export

On a defined schedule (typically monthly), VictoryAI generates EMR-ready data export files containing structured clinical data formatted for BayMark's billing workflow. Each export file includes the Part 2 redisclosure notice required by § 2.32(a). The export files are transferred to BayMark's designated SFTP endpoint with encryption in transit, and access to the exported files on BayMark's side is governed by BayMark's own access controls.

SECTION 06

Family Member Disclosure Architecture

The Family Reward Board feature creates a specific compliance question: how does the platform handle disclosures to a patient's family members under both HIPAA and Part 2? This section documents the architecture and the consent framework.

6.1 The Compliance Question

HIPAA permits disclosures of PHI to family members involved in the patient's care under § 164.510(b), subject to the patient's verbal or implicit agreement and the minimum necessary standard. Part 2 has historically been more restrictive: disclosures to family members generally required specific written patient consent. The 2024 Final Rule did not eliminate this distinction — Part 2's family disclosure rules remain more stringent than HIPAA's, even after the broader HIPAA alignment.

This means that the Family Reward Board must be architected so that any data flowing to a family member is either (a) not Part 2 information, or (b) flowing under a specific patient consent that meets the Part 2 standard.

6.2 How VictoryAI Implements Family Disclosure

VictoryAI's solution is architectural: family members do not see clinical data. The Family Reward Board interface presents to the family member only (a) the rewards the family member has personally pledged, (b) the milestones the patient has reached toward those pledged rewards (e.g., "45 days"), and (c) gratitude messages the patient has chosen to send. Family members do not see MAT adherence data, craving levels, COWS scores, voice journal content, mood data, CBT module completion, drug screen results, or any other clinical information.

The day count and milestone information shared with family members is, in VictoryAI's view, not Part 2 information per se because it does not identify the patient as someone who has received SUD treatment from a Part 2 program — the patient could have set the day counter themselves for any reason, and the family member's view does not include the underlying clinical context. However, this is a fact-specific legal question that BayMark's Part 2 counsel should evaluate. If BayMark's counsel concludes that even the day counter constitutes Part 2 information in this context, VictoryAI is prepared to require an additional patient consent specific to family disclosure as part of the family member onboarding flow.

6.3 Family Member Consent Requirements

Regardless of the Part 2 analysis above, the family member onboarding flow includes the following safeguards. First, the patient must affirmatively invite each family member; family members cannot self-enroll. Second, the patient may revoke any family connection at any time without explanation, and revocation immediately terminates the family member's access to all patient information. Third, the patient may flag any family member as inappropriate, which triggers a notification to the patient's BayMark clinician and removes the family member from the patient's network. Fourth, family members never have access to the patient app itself — they receive a separate, much more limited family-facing interface that displays only the milestones and pledged rewards relevant to their specific relationship.

These safeguards are designed to address the risk that family members in OUD recovery contexts can sometimes be sources of harm rather than support — including in cases of domestic violence, financial exploitation, or coercion. The patient retains complete control over which family members are connected and can disconnect at any time without involving anyone else.

SECTION 07

Voice Data Privacy Architecture

The Voice Journal feature creates the second compliance question that requires specific attention. Voice is identifiable in a way that text is not, and SUD voice recordings present particular privacy risks. This section documents how VictoryAI handles voice data.

7.1 The Privacy Risk

Raw voice recordings are biometric identifiers. They can be matched to a known speaker, used for re-identification of de-identified data, and processed for purposes the patient did not anticipate. In the SUD context, voice recordings carry the additional risk that they may contain spontaneous disclosures of relapse, illegal activity, or other content that the patient would not intentionally share with their clinician — content that, if mishandled, could expose the patient to legal or social harm.

7.2 VictoryAI's Architecture: On-Device Processing

VictoryAI's solution to the voice data privacy problem is to never transmit raw voice. When a patient records a voice journal entry, the audio is processed entirely on the patient's device. Local processing extracts (a) acoustic features for the vocal biomarker analysis (pitch variability, energy, prosodic markers, pause duration, etc.) and (b) a sentiment score derived from on-device natural language processing of the transcribed content. Only the extracted features and sentiment score are transmitted to VictoryAI servers. The raw audio file and the full transcript are deleted from the device immediately after feature extraction is complete.

This architecture means that VictoryAI never possesses, stores, or transmits raw voice recordings. There is no voice file in any VictoryAI database, no voice file in any backup, and no voice file in any audit log. The privacy protection is enforced at the architectural level, not at the policy level — VictoryAI cannot hand over raw voice in response to a subpoena because VictoryAI does not have raw voice.

7.3 Safety Classifier and Crisis Escalation

There is one exception to the on-device-only processing rule. The on-device NLP module includes a safety classifier that flags content indicative of suicidal ideation, self-harm intent, intent to relapse with high-risk substances, or domestic violence. When the safety classifier flags an entry, the metadata of the flagged event (not the raw audio, not the full transcript) is transmitted to VictoryAI's clinical safety officer and to the patient's assigned BayMark clinician within 15 minutes. The patient is notified in the app that a flag has been raised and is offered immediate connection to crisis resources.

The safety classifier creates a tension between absolute privacy and patient safety. VictoryAI's resolution is to flag the existence of a safety concern to the clinical team without transmitting the underlying content. This is the minimum disclosure consistent with the duty to escalate genuine crisis events, and it is documented in the patient consent flow so that patients understand the safety flag exception when they begin using the Voice Journal feature.

7.4 Spanish Language and Other Language Support

The on-device NLP and acoustic feature extraction support English and Spanish at pilot launch, with additional language support planned for post-pilot deployment. BayMark's BAART California population is significantly Spanish-speaking, and the pilot is designed to support those patients with feature parity. The clinical evidence base for voice biomarkers in non-English populations is more limited than the English-language base, and this limitation is explicitly disclosed in the patient consent flow.

SECTION 08

Breach Notification

The 2024 Final Rule extended the HIPAA Breach Notification Rule to Part 2 records, with effect from February 16, 2026. This section documents how VictoryAI handles potential breaches and meets its notification obligations.

8.1 Definition of a Breach

Under the HIPAA Breach Notification Rule (45 CFR § 164.402, now extended to Part 2), a breach is the acquisition, access, use, or disclosure of unsecured PHI in a manner not permitted by the Privacy Rule that compromises the security or privacy of the PHI. The rule includes a four-factor risk assessment for determining whether an impermissible use or disclosure constitutes a breach. PHI is unsecured if it has not been rendered unusable, unreadable, or indecipherable to unauthorized persons through encryption or destruction meeting HHS-specified standards.

VictoryAI's encryption posture (AES-256 at rest, TLS 1.3 in transit) is designed to render ePHI "secured" within the meaning of the rule, which means that an incident involving encrypted data that does not also involve compromise of the encryption keys is unlikely to constitute a reportable breach. Nevertheless, VictoryAI applies a conservative interpretation and treats any potentially impermissible access or disclosure as a candidate breach until the four-factor analysis is complete.

8.2 Detection and Discovery

Potential breach events are detected through multiple channels: automated security monitoring (SIEM-based intrusion detection), audit log review, vendor incident reports from subprocessors, workforce reports, and external notifications. Any detected event is logged in the incident management system and routed to the on-call security engineer for initial triage within one hour of discovery.

8.3 Investigation and Risk Assessment

Within 24 hours of discovery, VictoryAI's security team conducts an initial investigation to determine (a) whether ePHI was actually involved, (b) the scope of any potential disclosure, (c) whether the data was secured (encrypted), and (d) whether the four-factor risk assessment indicates a low probability that the PHI has been compromised. The investigation findings are documented in the incident record.

8.4 Notification to BayMark

If the investigation concludes that a breach has occurred (or that there is meaningful uncertainty about whether one has occurred), VictoryAI will notify BayMark's designated privacy contact without unreasonable delay and in no case later than 60 calendar days after discovery. VictoryAI's commitment to BayMark is to notify within 5 business days of discovery for any breach affecting more than 500 BayMark patients, and within 10 business days for smaller breaches — well inside the 60-day statutory maximum.

The notification will include the categories of information specified in 45 CFR § 164.410: identification of the affected individuals to the extent possible, a description of what happened, the types of unsecured PHI involved, what VictoryAI has done in response, what BayMark and the patients should do to protect themselves, and contact information for further questions. VictoryAI will provide BayMark with all information BayMark needs to make its own notifications to patients, the HHS Secretary, and (for breaches involving more than 500 individuals in a single state) prominent media outlets.

8.5 Coordination with BayMark on Patient Notification

Patient notification under HIPAA is the responsibility of the covered entity (BayMark), not the business associate (VictoryAI). However, VictoryAI commits to provide BayMark with draft notification language, technical assistance, and ongoing coordination throughout the notification process. VictoryAI will not communicate directly with affected patients about a breach without BayMark's explicit approval, and VictoryAI will not make any public statement about a breach without BayMark's coordination.

SECTION 09

Patient Consent and Patient Notice

The patient consent and notice infrastructure is the most patient-facing element of the compliance architecture, and the 2024 Final Rule made significant changes to both.

9.1 The Single TPO Consent Form

As noted in Section 3.2, the 2024 Final Rule permits a single patient consent for all future TPO uses and disclosures of Part 2 records. VictoryAI's onboarding flow uses a consent form that includes all of the elements required by 42 CFR § 2.31, presented in plain language at an approximately seventh-grade reading level (consistent with HHS guidance and with the patient population served by BayMark's BAART California clinics). The consent form will be developed jointly with BayMark and reviewed by BayMark's privacy officer before pilot launch.

The consent form includes: (a) the patient's name, (b) the type of records to be disclosed, (c) the categories of recipients (BayMark, VictoryAI, BayMark's billing staff, the patient's care team, and any subprocessors of VictoryAI), (d) the purposes (treatment, payment, healthcare operations, pilot evaluation), (e) the patient's right to revoke the consent in writing at any time, (f) the prohibition on conditioning treatment on providing the consent, (g) the date or condition on which the consent expires, and (h) the patient's signature and the date.

9.2 Patient Notice of Privacy Practices

The 2024 Final Rule aligned the Part 2 patient notice requirements with HIPAA's Notice of Privacy Practices requirements and permits Part 2 programs to combine the HIPAA NPP, the Part 2 patient notice, and any state law notices into a single document, provided that all required elements are included. BayMark's existing HIPAA NPP will be reviewed and updated as needed to incorporate the Part 2 elements added by the 2024 Final Rule, including the explicit statement about the limits on use of SUD records in legal proceedings (per 42 CFR § 2.22).

VictoryAI will display BayMark's combined HIPAA/Part 2 patient notice within the patient app onboarding flow. The notice will be available for review at any point in the app via the Profile screen and will be updated whenever BayMark updates its NPP.

9.3 Plain-Language Translation

All consent forms and patient notices used in the pilot will be available in English and Spanish, with the Spanish translation reviewed by a qualified medical translator. The translation will preserve all required regulatory elements while maintaining readability for the BAART California Spanish-speaking patient population.

SECTION 10

Subprocessors and the BAA Chain

VictoryAI uses several third-party services to deliver the platform. Each service that processes PHI is a HIPAA subcontractor and must have a downstream Business Associate Agreement in place with VictoryAI before any PHI flows to it.

10.1 Current Subprocessor List

Subprocessor	Function	Data Handled	BAA Status
Amazon Web Services	Cloud hosting (HIPAA-eligible services only)	Encrypted ePHI at rest, all production data	Executed (AWS BAA)
Twilio	Patient app notifications and SMS support	Phone numbers, message metadata only	Executed (Twilio BAA)
SendGrid / Postmark	Transactional email	Email addresses, no clinical content	Executed
Datadog	Application monitoring and audit log SIEM	Audit metadata, no PHI in event payloads	Executed (Datadog BAA)
Anthropic	Sage AI conversational engine	De-identified message content; no patient identifiers	Per Anthropic enterprise terms; under review
Stripe	Pilot fee payment processing	BayMark billing data only; no patient PHI	Not applicable (no PHI)

10.2 Subprocessor Onboarding Process

Before any new subprocessor is added to the platform, VictoryAI conducts a vendor security assessment that includes review of the subprocessor's HIPAA compliance posture, willingness to execute a BAA, security certifications (SOC 2 Type II, HITRUST, or equivalent), data residency, breach notification commitments, and subprocessor chain. The assessment is documented and retained for the duration of the relationship plus six years.

10.3 AI Subprocessor Specific Considerations

The use of large language models for the Sage AI conversational engine creates a specific compliance question that BayMark's compliance team should be aware of. VictoryAI uses Anthropic's Claude API with explicit zero-data-retention configuration for any data flowing through

the API. Patient identifiers are stripped before any text is sent to the model, and the model's responses are processed back to the patient app without being stored in any third-party log. The architecture is designed to ensure that no identifiable patient data is retained by Anthropic and that the LLM relationship operates within HIPAA business associate constraints.

BayMark's compliance team should specifically review and approve VictoryAI's LLM subprocessor architecture during pilot setup. This is a relatively new compliance frontier and VictoryAI welcomes the diligence.

SECTION 11

California-Specific Considerations

The pilot is being conducted at BayMark's California BAART clinics, which adds California-specific compliance considerations on top of the federal regulatory framework.

11.1 California Confidentiality of Medical Information Act (CMIA)

CMIA, codified at California Civil Code §§ 56–56.37, is California's primary medical privacy law. It generally provides protections similar to HIPAA but adds California-specific elements. The most important CMIA provisions for the pilot are: (a) the requirement that any disclosure of medical information be made under a valid authorization or under an enumerated exception, (b) the private right of action that allows individuals to sue for improper disclosure of their medical information with statutory damages, and (c) the special protections for mental health and substance use information.

The CMIA preemption analysis with HIPAA and Part 2 is fact-specific. In general, the more protective rule applies. BayMark's California compliance counsel should conduct a formal preemption analysis as part of pilot setup, particularly with respect to the CMIA private right of action, which is a meaningful additional litigation risk that does not exist under federal HIPAA enforcement.

11.2 California Consumer Privacy Act and California Privacy Rights Act

CCPA and CPRA generally exempt PHI subject to HIPAA and patient information collected by covered entities or business associates in their capacity as such. VictoryAI takes the position that the patient app and provider dashboard data flows are within the medical information exemption to CCPA/CPRA. However, the exemption is narrower than many vendors assume, and BayMark's California privacy counsel should independently confirm the analysis. Specific issues to evaluate include the treatment of de-identified data, the treatment of data collected from family members (who are not patients of BayMark), and the treatment of any data used for purposes outside the strict HIPAA permitted uses.

11.3 Drug Medi-Cal Organized Delivery System

BayMark's BAART California clinics participate in DMC-ODS, which adds DHCS-specific reporting and compliance requirements. VictoryAI's data capture and reporting architecture is designed to support BayMark's DMC-ODS reporting obligations, and the pilot can produce de-identified outcomes data that BayMark may share with DHCS without separate patient consent

(per the public health authority disclosure provision of the 2024 Final Rule, discussed in Section 3.5).

11.4 California Mental Health Information

California Welfare and Institutions Code § 5328 provides additional confidentiality protections for mental health information. Because OUD is classified as a mental disorder under DSM-5-TR and because many BayMark patients have co-occurring mental health conditions, the § 5328 protections may apply to some data flows in the pilot. BayMark's California counsel should evaluate this question.

SECTION 12

Audit, Documentation, and Workforce Training

12.1 Documentation Retention

HIPAA requires that policies, procedures, and documentation related to compliance be retained for a minimum of six years from the date of creation or the date last in effect, whichever is later. VictoryAI retains all compliance documentation — including risk assessments, incident records, audit logs, training records, BAAs, and patient consents — for a minimum of seven years to provide a safety margin over the statutory minimum. Documentation is stored in encrypted, immutable storage with role-based access.

12.2 Audit Log Architecture

Audit logs capture every access to or modification of ePHI, including unique user ID, timestamp, source IP and device, action taken, and affected records. Logs are routed to a centralized SIEM (Datadog) with immutable storage. The SIEM is configured with automated alerting for high-risk events including failed authentication attempts above threshold, privilege escalations, unusual data access patterns, and any access to records flagged as Part 2-protected by users not previously authorized for that patient.

12.3 Workforce Training

VictoryAI workforce members complete the following training: (a) general HIPAA Privacy and Security training at hire and annually, (b) 42 CFR Part 2 specific training before being granted access to Part 2 records and annually thereafter, (c) role-specific security training (secure coding for engineers, incident response for operations, social engineering awareness for all staff), and (d) any BayMark-specific training that BayMark requires of business associate workforce members. All training is documented with date, content, and employee acknowledgment.

12.4 Annual Risk Assessment

VictoryAI conducts a HIPAA Security Risk Assessment annually, following the OCR Security Risk Assessment Tool framework or an equivalent methodology. The most recent assessment will be made available to BayMark's information security team prior to contract execution. The next scheduled assessment will be conducted within 12 months of the prior assessment, and any material change to the platform or to the threat environment will trigger an interim assessment.

12.5 SOC 2 and Other Certifications

VictoryAI is currently in the SOC 2 Type 1 readiness phase, with Type 1 attestation expected within 90 days of pilot launch and Type 2 attestation expected within 12 months. BayMark's information security team will receive draft SOC 2 documentation as it becomes available, along with the timeline for full Type 2 certification. VictoryAI is not currently HITRUST certified; HITRUST certification will be evaluated post-pilot based on enterprise customer requirements.

SECTION 13

Open Items for BayMark Legal and Compliance Review

This section lists the specific items that BayMark's legal, privacy, and information security teams should evaluate before contract execution. These are not red flags — they are the standard due diligence items that BayMark should expect to address with any vendor handling SUD patient data.

Legal Review

6. Conduct CMIA preemption analysis to confirm that VictoryAI's data handling satisfies California-specific requirements that exceed HIPAA and Part 2.
7. Review the patient consent form (developed jointly) for compliance with 42 CFR § 2.31 elements and for plain-language readability.
8. Review the combined HIPAA/Part 2 Notice of Privacy Practices that BayMark will provide to pilot patients.
9. Evaluate the family member disclosure architecture (Section 6) and confirm whether additional patient consent is required for the day-counter information shared with family members.
10. Confirm that the pilot agreement language preserves the § 2.13(a) prohibition on use of Part 2 records in legal proceedings against patients.
11. Review VictoryAI's response to subpoenas, discovery requests, and law enforcement requests for Part 2 records and confirm that BayMark will be notified before any disclosure.

Privacy Officer Review

12. Review VictoryAI's HIPAA Security Risk Assessment for completeness and recency.
13. Review VictoryAI's incident response procedures and confirm that the 5/10 business day notification commitment to BayMark is acceptable.
14. Confirm that VictoryAI's audit log retention and access procedures support BayMark's needs for accounting of disclosures.
15. Review the patient rights infrastructure for accounting of disclosures and restriction requests.
16. Confirm that BayMark's existing NPP can be updated to incorporate the Part 2 elements added by the 2024 Final Rule, or determine whether a new combined NPP is needed.

Information Security Officer Review

17. Review VictoryAI's technical safeguards documentation against the BayMark security policy.
18. Conduct or review penetration testing results from VictoryAI's third-party pen test (or commission a new test as part of pilot setup if needed).
19. Review VictoryAI's subprocessor list, focusing on the AI/LLM subprocessor architecture and the AWS BAA chain.
20. Evaluate VictoryAI's encryption posture (AES-256 at rest, TLS 1.3 in transit) against BayMark's encryption requirements.
21. Review VictoryAI's MFA implementation and session management policies.
22. Confirm VictoryAI's SOC 2 timeline and accept the Type 1 attestation as the baseline for pilot launch with Type 2 to follow within 12 months.

Part 2 Compliance Officer Review

23. Confirm the lawful holder relationship structure described in Section 2.2 and the BAA additions described in Section 2.3.
24. Verify that the SUD counseling notes architectural exclusion (Section 3.4) is implemented as described.
25. Review the data flow architecture in Section 5 and confirm that segmentation, while not required by the Final Rule, is being implemented as a defense-in-depth measure.
26. Confirm that any planned disclosures to public health authorities will use Safe Harbor or Expert Determination de-identification.
27. Review the patient consent revocation procedures and confirm that revocation will be implemented across the platform within the committed timeframe.

SECTION 14

VictoryAI's Compliance Commitments to BayMark

This section enumerates the specific commitments VictoryAI is willing to make to BayMark as part of the pilot agreement. These are commitments VictoryAI is prepared to write into the BAA or the pilot Statement of Work, not aspirational statements.

Commitments

28. VictoryAI will execute BayMark's standard Business Associate Agreement, with reasonable additions for the Part 2 lawful holder context.
29. VictoryAI will deliver its current HIPAA Security Risk Assessment to BayMark's information security team within 5 business days of pilot agreement execution.
30. VictoryAI will achieve SOC 2 Type 1 attestation within 90 days of pilot launch and SOC 2 Type 2 attestation within 12 months of pilot launch.
31. VictoryAI will notify BayMark of any potential breach affecting more than 500 BayMark patients within 5 business days of discovery, and any smaller potential breach within 10 business days.
32. VictoryAI will maintain a current subprocessor list and notify BayMark of any addition or change to subprocessors handling PHI at least 30 days in advance of the change taking effect.
33. VictoryAI will support BayMark's accounting of disclosures requests within 30 days of receipt.
34. VictoryAI will implement patient consent revocations across all systems within 5 business days of receipt.
35. VictoryAI will not use any pilot data for any purpose outside the agreed pilot scope without separate BayMark approval.
36. VictoryAI will return or destroy all PHI in its possession at pilot termination or contract end, per the BAA terms, with documented destruction certification.
37. VictoryAI will cooperate with any BayMark-initiated audit of VictoryAI's compliance posture during the pilot, with reasonable advance notice.
38. VictoryAI will not communicate with patients, family members, regulators, or media about any breach or compliance incident without BayMark's explicit prior approval.
39. VictoryAI will participate in joint regulatory response if any pilot data becomes the subject of a Part 2 or HIPAA enforcement action.

VictoryAI's compliance posture is designed to make BayMark's diligence as efficient as possible. This memorandum exists to lay out the architecture, the controls, and the open items in one structured document — so that BayMark's legal, privacy, security, and compliance teams can review the pilot proposal in parallel rather than sequentially. Where this memorandum is wrong or incomplete on any point, BayMark's review will identify the gap, and VictoryAI will address it before contract execution.

APPENDIX A

Authorities and References

All statutory and regulatory citations in this memorandum reference the United States Code or the Code of Federal Regulations as in effect on April 8, 2026. BayMark's legal team should verify currency before relying on any citation.

Federal Statutes

- Health Insurance Portability and Accountability Act of 1996, Public Law 104-191
- Health Information Technology for Economic and Clinical Health Act, Title XIII of the American Recovery and Reinvestment Act of 2009, Public Law 111-5
- Coronavirus Aid, Relief, and Economic Security Act of 2020, Public Law 116-136 (Section 3221 directs alignment of 42 CFR Part 2 with HIPAA)
- 42 USC § 290dd-2 (Confidentiality of records)

Federal Regulations

- HIPAA Privacy Rule: 45 CFR Parts 160 and 164, Subparts A and E
- HIPAA Security Rule: 45 CFR Parts 160 and 164, Subparts A and C
- HIPAA Breach Notification Rule: 45 CFR Parts 160 and 164, Subpart D
- HIPAA Enforcement Rule: 45 CFR Part 160, Subpart D
- 42 CFR Part 2 — Confidentiality of Substance Use Disorder Patient Records (as modified by the 2024 Final Rule)

Key Rulemaking Documents

- Confidentiality of Substance Use Disorder (SUD) Patient Records, Final Rule, 89 Fed. Reg. 12472 (Feb. 16, 2024). Effective April 16, 2024; compliance required Feb. 16, 2026.
- HIPAA Security Rule To Strengthen the Cybersecurity of Electronic Protected Health Information, Notice of Proposed Rulemaking, 90 Fed. Reg. 898 (Jan. 6, 2025). Not yet finalized as of April 2026.
- Modifications to the HIPAA Privacy, Security, Enforcement, and Breach Notification Rules Under the HITECH Act and the Genetic Information Nondiscrimination Act, Final Rule, 78 Fed. Reg. 5566 (Jan. 25, 2013) ("2013 Omnibus Rule")

HHS Guidance Documents

- HHS Office for Civil Rights, Fact Sheet: 42 CFR Part 2 Final Rule (2024), available at hhs.gov/hipaa/for-professionals/regulatory-initiatives/fact-sheet-42-cfr-part-2-final-rule

- HHS Office for Civil Rights, Civil Enforcement Program for Confidentiality of Substance Use Disorder Patient Records (announced Feb. 13, 2026, enforcement began Feb. 16, 2026)
- HHS Office for Civil Rights, Summary of the HIPAA Security Rule, hhs.gov/hipaa/for-professionals/security/laws-regulations
- HHS Office for Civil Rights, Resources for Mobile Health App Developers
- SAMHSA Center of Excellence for Protected Health Information, guidance materials on Part 2 compliance
- OCR Advisory Opinion 22-04 (Digital Contingency Management Program, 2022)

California Authorities

- California Confidentiality of Medical Information Act, Cal. Civ. Code §§ 56–56.37
- California Consumer Privacy Act, Cal. Civ. Code § 1798.100 et seq., as amended by the California Privacy Rights Act
- California Welfare and Institutions Code § 5328 (mental health information confidentiality)
- California Department of Health Care Services, Drug Medi-Cal Organized Delivery System (DMC-ODS) Standard Terms and Conditions

APPENDIX B

Glossary of Terms

Term	Definition
BAA	Business Associate Agreement. The contract required under HIPAA between a covered entity and a business associate (or between a business associate and a subcontractor) before any PHI can flow between them.
Breach	Under HIPAA, the acquisition, access, use, or disclosure of unsecured PHI in a manner not permitted by the Privacy Rule that compromises the security or privacy of the PHI. Subject to the four-factor risk assessment at 45 CFR § 164.402.
Business Associate	A person or entity that, on behalf of a covered entity, creates, receives, maintains, or transmits PHI for a HIPAA-regulated function. Subject to direct HIPAA liability since HITECH (2009).
Covered Entity	A health plan, healthcare clearinghouse, or healthcare provider that transmits health information in electronic form in connection with a HIPAA-standard transaction.
CMIA	California Confidentiality of Medical Information Act. California's primary medical privacy law, with some provisions more protective than HIPAA, including a private right of action.
DMC-ODS	Drug Medi-Cal Organized Delivery System. California's Medicaid SUD treatment delivery system, operated by DHCS.
ePHI	Electronic Protected Health Information. PHI maintained in or transmitted by electronic media. Subject to the HIPAA Security Rule.
Final Rule (2024)	The Final Rule modifying 42 CFR Part 2, published February 16, 2024. Effective April 16, 2024. Compliance required by February 16, 2026.
HITECH Act	Health Information Technology for Economic and Clinical Health Act of 2009. Strengthened HIPAA, made business associates directly liable, and established the breach notification framework.
Lawful Holder	Under 42 CFR Part 2, an entity that has received Part 2 records pursuant to a valid patient consent. Lawful holders may use and redisclose Part 2 records as permitted by the consent and the Final Rule.
MFA	Multi-factor authentication. Authentication requiring two or more verification factors. Currently addressable under the HIPAA Security Rule; proposed to become required under the January 2025 NPRM.
NPP	Notice of Privacy Practices. The patient-facing notice required under HIPAA describing how PHI may be used and disclosed. The 2024 Final

Term	Definition
	Rule aligned Part 2 patient notice requirements with HIPAA NPP requirements.
OCR	HHS Office for Civil Rights. The federal agency with primary enforcement authority over HIPAA and (since February 16, 2026) 42 CFR Part 2.
Part 2	42 CFR Part 2. Federal regulation establishing heightened confidentiality protections for SUD treatment records. Significantly modified by the 2024 Final Rule.
Part 2 Program	An individual or entity that meets the definition at 42 CFR § 2.11 — federally assisted, holds itself out as providing SUD treatment, and provides such treatment.
PHI	Protected Health Information. Individually identifiable health information held or transmitted by a covered entity or business associate.
RTM	Remote Therapeutic Monitoring. The CPT code category (98975–98981) introduced by CMS in 2022 to reimburse providers for collection and management of non-physiological patient data, including data from mobile applications.
SAMHSA	Substance Abuse and Mental Health Services Administration. The HHS agency responsible for SUD-related federal policy, including 42 CFR Part 2 (jointly with OCR).
SOC 2	Service Organization Control 2. An attestation framework developed by AICPA addressing security, availability, processing integrity, confidentiality, and privacy. Type 1 attests to controls at a point in time; Type 2 attests to operating effectiveness over a period (typically 6–12 months).
SUD Counseling Notes	A new protected category created by the 2024 Final Rule, defined as notes recorded by a SUD clinician documenting a counseling session, maintained separately from the rest of the patient's record. Analogous to HIPAA psychotherapy notes; requires specific consent.
TPO	Treatment, Payment, and Healthcare Operations. The three categories of uses and disclosures permitted under HIPAA without separate patient authorization. The 2024 Final Rule now permits a single Part 2 consent covering all three TPO categories.